

Prasad's Notes for NDC

NETWORK DEFENSE AND COUNTERMEASURES (NDC)

Study Notes

Covers: Information Security Concepts | Firewalls & iptables | Wireshark | VPN & IPsec | IDS/IPS | SIEM & Monitoring

Prepared in simple, easy-to-understand English for quick revision

Includes labelled diagrams for DMZ, Firewall Types, IDS vs IPS, VPN Tunnels, and SIEM Log Flow

How to Use This Document

This guide is organized to make revision fast and simple:

- Units 1-6 cover the ENTIRE syllabus, topic by topic, in plain English with real-life examples.
- Yellow boxes marked 'IMPORTANT' highlight the points most likely to be asked in exams — read these first if short on time.
- Blue boxes marked 'Example' give a real-world scenario to help the concept stick in memory.
- 6 diagrams are placed exactly where they are discussed - use them as visual anchors when revising.
- A 40-question quiz (mix of easy and tricky questions) appears after the notes, followed by a full Answer Key with explanations.

IMPORTANT: Try answering the 40 MCQs WITHOUT looking at the notes first - this tests real understanding, which is what exams actually check.

UNIT 1 — Foundations of Information & Network Security

1.1 What is Information Security?

Information Security means protecting information (data) from being seen, changed, or destroyed by people who are not allowed to do so. Think of it like locking your house — you protect your belongings from thieves. In the same way, organizations protect their data from hackers.

- It covers protection of data whether it is stored on a computer, travelling over a network, or being processed.
- It is not just about computers — it also includes people, processes, and policies.

Example: A bank protects customer account details so that only the customer and authorized bank staff can view or change them.

Why Information Security? (Why do we need it?)

- Businesses run on data — losing or leaking data can stop operations completely.
- Attackers can steal money directly (bank fraud) or indirectly (selling stolen data).
- Laws (like data protection acts) legally require organizations to protect user data.
- Reputation — a single data breach can destroy customer trust built over years.

Security: The Money Factor Involved

Security is also a business decision, not just a technical one. Every organization must balance the cost of security controls against the cost of a potential breach.

- Cost of protection: firewalls, IDS/IPS, VPNs, training, audits, staff.
- Cost of a breach: fines, lawsuits, lost customers, downtime, recovery cost.

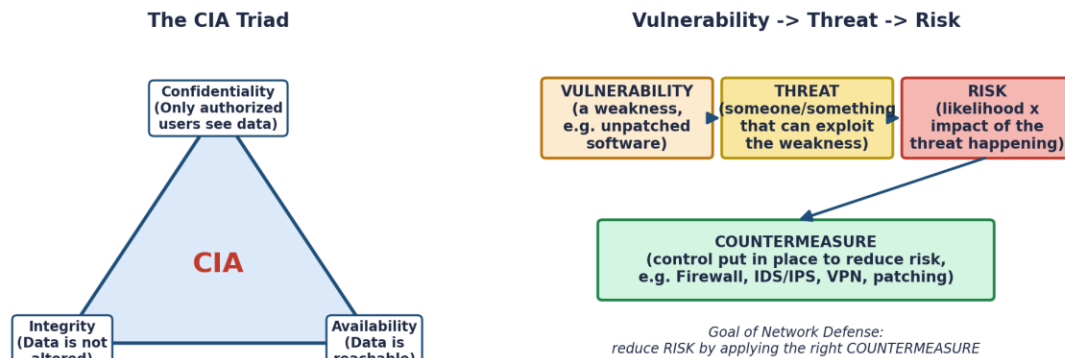
IMPORTANT: Spending on security should be proportional to the value of the asset being protected. Spending more to protect an asset than the asset is worth is wasteful; spending too little leaves valuable assets exposed.

Internet Statistics — A Security Perspective

When we look at internet growth statistics (billions of users, billions of connected IoT devices, huge growth in e-commerce and cloud usage), it tells us that the 'attack surface' — the number of possible entry points for an attacker — keeps growing every year. More devices and users online means more opportunities for attackers.

Vulnerability, Threat and Risk

These three words are the foundation of all network security. Students often confuse them, so remember this simple chain:



- Vulnerability — a weakness or flaw in a system (e.g., an unpatched operating system, a weak password policy, an open port).
- Threat — anyone or anything that can exploit a vulnerability (e.g., a hacker, a virus, a natural disaster, even a careless employee).
- Risk — the probability that a threat will actually exploit a vulnerability, combined with the impact/damage it would cause. Risk = Likelihood × Impact.
- Countermeasure (also called a control) — anything put in place to reduce risk, such as a firewall, IDS/IPS, VPN, patch, or training program.

IMPORTANT: Exam tip: Vulnerability is the WEAKNESS, Threat is the ATTACKER/DANGER, Risk is the CHANCE OF LOSS. Countermeasure is the FIX.

QoS — Quality of Service

QoS refers to the overall performance of a network, especially the performance experienced by the users. In security labs, we also study QoS because attacks (like DDoS) directly damage QoS.

- Latency — the delay between sending and receiving data (measured in milliseconds).
- Jitter — variation in latency/delay over time; important for video calls and VoIP.
- Packet Loss — percentage of data packets that fail to reach their destination.
- Bandwidth/Throughput — the actual amount of data successfully transferred per second.

Example: During a DDoS attack, packet loss and latency shoot up sharply — this is one way network defenders realize an attack is happening.

1.2 Risk Management, Exposure and Countermeasure

Risk Management is the ongoing process of identifying, evaluating, and reducing risk to an acceptable level. It never makes risk zero — that is impossible — it only reduces it to something the organization can accept.

Steps of Risk Management

- 1. Identify assets — what needs protection (servers, data, applications).
- 2. Identify vulnerabilities and threats to those assets.
- 3. Assess risk — estimate likelihood and impact.
- 4. Treat risk — apply countermeasures, transfer risk (insurance), accept risk, or avoid the activity.
- 5. Monitor continuously — risk changes as new threats appear.

Exposure

Exposure is the extent to which an asset is open or unprotected against a threat. The bigger the exposure (e.g., a server directly facing the internet with no firewall), the higher the risk.

IMPORTANT: Reducing EXPOSURE (e.g., placing a server behind a firewall/DMZ instead of directly on the internet) is one of the simplest and most effective ways to reduce overall risk.

1.3 Case-Study Thinking — How to Analyze a Breach

Whenever you study a real-world security breach (self-learning topic), always analyze it using this standard 4-point method:

- Attack Vector — HOW did the attacker get in (phishing email, unpatched server, weak VPN password)?
- Vulnerability Exploited — WHICH weakness allowed the attack to succeed?
- Financial Impact — how much money was lost (fines, ransom, downtime)?
- Reputational Impact — how much customer trust and brand value was lost?

Example: A retail company breach: Attack vector = stolen third-party vendor credentials; Vulnerability = no multi-factor authentication; Financial impact = regulatory fines; Reputational impact = loss of customer confidence and stock price drop.

UNIT 2 — Firewalls & Perimeter Defense

2.1 What is a Firewall?

A firewall is a security device (hardware, software, or both) that monitors and controls incoming and outgoing network traffic based on a set of pre-defined security rules. Think of it like a security guard standing at the entrance of a building, checking every visitor against a list before letting them in or out.

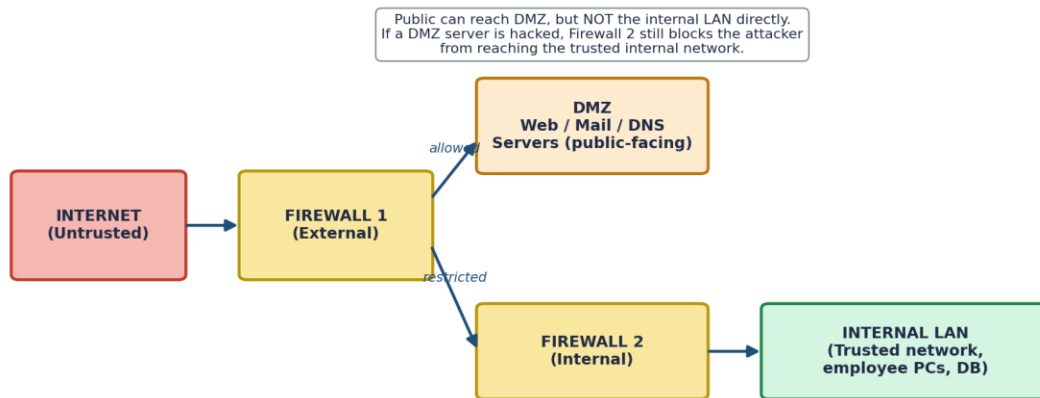
- It sits between a trusted network (your organization/LAN) and an untrusted network (the internet).
- It decides to ACCEPT, DROP, or REJECT traffic based on rules (source/destination IP, port, protocol).

IMPORTANT: A firewall protects the perimeter (the boundary), but it cannot stop every attack — for example, it usually cannot stop an attack that comes from an already-authorized/legitimate connection (this is why we also need IDS/IPS).

De-Militarized Zone (DMZ)

A DMZ is a separate, semi-trusted network segment that sits between the internal (trusted) LAN and the internet (untrusted). Public-facing servers — like web servers, mail servers, and DNS servers — are placed here.

Firewall Placement and DMZ (De-Militarized Zone) Architecture

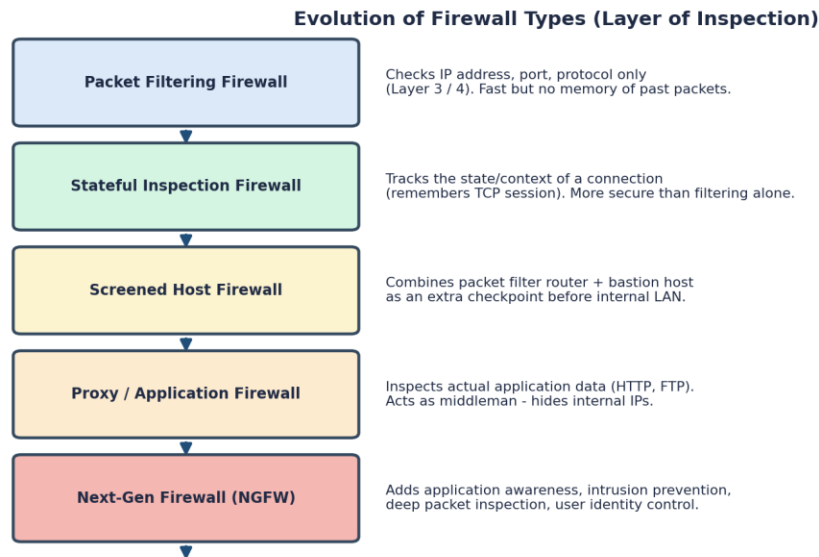


- If a server in the DMZ gets hacked, the attacker still cannot directly reach the internal LAN because another firewall separates the DMZ from the internal network.
- The name comes from the military term for a buffer zone between two opposing forces.

Two Methods of Implementing a Firewall

- **Screened Subnet (Dual-Firewall / Two-Firewall Architecture)** — one firewall between internet and DMZ, a second firewall between DMZ and internal LAN. This is the most secure design (shown in the diagram above).
- **Single-Firewall (Three-Legged) Architecture** — one single firewall device with three network interfaces: one to the internet, one to the DMZ, and one to the internal LAN. Cheaper but has a single point of failure.

2.2 Types of Firewalls



Packet Filtering Firewall

This is the simplest and oldest type. It examines each packet in isolation and checks the source IP, destination IP, source port, destination port, and protocol against a rule list. It does NOT remember previous packets.

- Fast and low-cost, works at the Network/Transport layer (Layer 3/4).
- Weakness: cannot understand the context of a connection, so it is vulnerable to IP spoofing and cannot detect attacks hidden inside allowed traffic.

Screened Host Firewall

Combines a packet-filtering router with a bastion host (a hardened server). The router filters traffic first, then forwards permitted traffic to the bastion host, which does more detailed checking before letting traffic enter the internal LAN.

Stateful Inspection Firewall

This is smarter than simple packet filtering. It keeps a 'state table' that remembers the status of every active connection (e.g., a TCP handshake in progress). It only allows response packets that match an existing, legitimate connection.

Example: If your PC opens a connection to a website, the stateful firewall remembers this and allows the website's reply packets back in — but it will block an unsolicited packet pretending to be a reply to a connection that was never opened.

NextGen Firewall (NGFW) — Application Controls

An NGFW goes far beyond IP/port filtering. It can see and control traffic at the application layer.

- Deep Packet Inspection (DPI) — looks inside the packet payload, not just the header.
- Application awareness — can allow Facebook chat but block Facebook games, for example.
- Built-in Intrusion Prevention, malware filtering, and user-identity-based rules.

IMPORTANT: Exam tip — remember the ladder: Packet Filter (header only) → Stateful (remembers connections) → Proxy/Application (reads actual data) → NGFW (all of the above + identity + IPS).

2.3 iptables — The Linux Firewall

iptables is the built-in firewall utility in Linux. It works by applying rules to 'chains' inside different 'tables'. Every network packet that touches the Linux machine passes through these chains, and iptables decides its fate.

iptables — Tables

- filter table — the default table; used for allowing/blocking traffic (most common use).
- nat table — used for Network Address Translation (changing source/destination addresses, e.g., port forwarding).
- mangle table — used for specialized packet alteration (e.g., changing TTL, marking packets for QoS).

iptables — Predefined Chains (inside the filter table)

Chain	Purpose	Example use
INPUT	Controls packets destined FOR this local machine.	Block an outsider from SSH-ing into this server.
OUTPUT	Controls packets that ORIGINATE from this local machine.	Stop this machine from contacting a known malicious IP.
FORWARD	Controls packets PASSING THROUGH this machine (acting as a router).	This machine routes traffic between two LANs/subnets.

iptables — Rule Processing & Default Policy

- Rules inside a chain are checked TOP TO BOTTOM, in order — the first matching rule wins.
- Default Policy is what happens if NO rule matches (commonly set to DROP for security — 'deny by default').

IMPORTANT: Best practice (deny by default): set default policy to DROP, then explicitly ACCEPT only the traffic you need. This is far safer than allowing everything and trying to block bad traffic one by one.

iptables / Netfilter — Targets

- ACCEPT — allow the packet through.
- DROP — silently discard the packet (attacker gets no response, harder to detect the firewall).
- REJECT — discard the packet but send back an error message (e.g., ICMP unreachable) to the sender.
- LOG — record the packet details in the system log (used with other targets for auditing).

Netfilter / Xtables-Addons — Internal Working

Netfilter is the actual kernel framework inside Linux that iptables talks to. iptables is just the user-friendly command-line tool; Netfilter is the engine doing the real packet interception inside the kernel. Xtables-Addons extends Netfilter/iptables with extra modules (e.g., GeoIP matching).

SPI Firewall (Stateful Packet Inspection)

An SPI firewall is simply a firewall that performs stateful inspection (explained above) — it is a common marketing/technical term used especially for home/office routers and firewall appliances.

iptables IPv6 Rule Management

Because IPv6 uses a different addressing system than IPv4, a separate command `ip6tables` is used to manage IPv6 firewall rules. Rules written in `iptables` (IPv4) do NOT automatically apply to IPv6 traffic — both must be configured separately, otherwise IPv6 traffic can slip past your IPv4-only firewall rules unnoticed.

Advanced iptables Topics

- Loading Modules — `iptables` can load kernel modules for extra matching capability, e.g., 'connlimit', 'recent', 'geoip'.
- GeoIP Blocking (Xtables-Addons) — blocks or allows traffic based on the country an IP address belongs to. Useful to block traffic from countries where your organization has no legitimate users.
- Access Control using `iptables` — restricting which internal hosts can access which external resources.
- Internet Sharing using `iptables` — using NAT (MASQUERADE) so multiple internal devices can share one public IP to access the internet.
- Port Forwarding — redirecting incoming traffic on one port/IP to a different internal IP/port (commonly used to expose an internal server safely).
- Fail2ban — a tool that reads log files (e.g., failed SSH logins) and automatically creates temporary `iptables` ban rules for IPs that show malicious behavior (like repeated failed logins).

IMPORTANT: Stateless vs Stateful — Stateless firewalls check every packet independently (fast, less secure). Stateful firewalls remember connection context (slightly slower, much more secure). Most modern firewalls are stateful.

IMPORTANT: Traditional Firewall vs NGFW — Traditional firewalls only look at IP/port; NGFW looks at applications, users, and content, and often includes IPS built in.

2.4 Linux Software Firewalls, Reverse Proxy, UTM & Load Balancing

pfSense & ClearOS

pfSense and ClearOS are free, open-source, Linux/BSD-based operating systems designed specifically to work as a full firewall + router appliance, complete with an easy web-based interface. They are widely used in labs and small/medium businesses because they combine firewall, VPN, and routing features in one system.

Nginx & Squid — Reverse Proxy

A reverse proxy sits in FRONT of one or more backend web servers and forwards client requests to them, then returns the server's response back to the client. The client only ever talks to the proxy — never directly to the real server.

- Hides the real IP address and internal structure of backend servers (extra security).
- Can perform SSL termination — decrypting HTTPS traffic at the proxy so backend servers don't have to.
- Server Farming / Load Balancing — a reverse proxy can distribute requests among many identical backend servers.
- Configuring reverse proxy URLs using regex allows flexible routing rules, e.g., forwarding '/api/*' requests to one server and '/images/*' to another.

IMPORTANT: Forward Proxy vs Reverse Proxy: A forward proxy hides and protects the CLIENT (used by internal users to browse the internet). A reverse proxy hides and protects the SERVER (used by websites to protect their backend).

UTM — Unified Threat Management

A UTM device combines MANY security functions into a single box: firewall, antivirus, IDS/IPS, VPN, content filtering, and spam filtering — all managed from one console.

- Advantage: simpler management, one device instead of many, often cheaper for small organizations.
- Disadvantage: single point of failure; may not perform as well as dedicated best-in-class devices for each function.

IMPORTANT: UTM vs NGFW: A UTM focuses on bundling MANY security tools together in one box for simplicity. An NGFW focuses on doing deep, intelligent traffic inspection (application-awareness) extremely well, and is generally faster/more scalable for large networks.

Server Load Balancing

A load balancer distributes incoming client requests across multiple servers so that no single server is overwhelmed. This improves both performance (faster responses) and availability (if one server fails, others keep serving traffic).

Example: An e-commerce website during a big sale uses a load balancer to spread millions of visitors across 20 identical web servers instead of crashing one single server.

IMPORTANT: Load Balancer vs Reverse Proxy: every load balancer is a form of reverse proxy, but a reverse proxy's main job may just be forwarding/hiding servers, while a load balancer's main job is specifically distributing load evenly (often using algorithms like round-robin, least-connections).

Reverse Proxies & DDoS / Application-Layer Attack Protection

- A reverse proxy can absorb and filter huge volumes of traffic before it reaches the real server, reducing the impact of a DDoS attack.
- It can inspect HTTP-level requests to catch application-layer attacks (like malicious form submissions or bad HTTP headers) that a simple network firewall would never see.

UNIT 3 — Wireshark & Packet-Level Analysis

3.1 What is Wireshark?

Wireshark is a free, open-source network protocol analyzer (a 'packet sniffer'). It captures the actual data travelling across a network interface and lets you inspect every single packet in detail — almost like an X-ray for network traffic.

- Used by network defenders to troubleshoot problems AND to detect suspicious/malicious activity.
- Shows details at every layer: Ethernet (Layer 2), IP (Layer 3), TCP/UDP (Layer 4), and Application data (HTTP, DNS, TLS, etc.).

Capture Filters vs Display Filters

Type	When applied	Purpose
Capture Filter	BEFORE capturing (at the network card)	Decides WHICH packets are captured at all — reduces file size, e.g. 'host 10.0.0.5'
Display Filter	AFTER capturing (on already-saved packets)	Decides WHICH captured packets are SHOWN on screen, e.g. 'http.request'

IMPORTANT: A common exam trap: capture filters use a DIFFERENT, simpler syntax (based on BPF) than display filters (which use Wireshark's own filter language). You cannot always use the same filter text in both boxes.

Examining Real-World Packet Captures

- TCP handshake analysis (SYN, SYN-ACK, ACK) — helps confirm whether a connection was properly established.
- TLS/HTTPS handshake — shows encryption negotiation without revealing actual encrypted content.
- HTTP requests/responses — visible in plain text if not encrypted, useful for spotting data leaks.
- Kerberos traffic — used to study authentication in Windows domain environments.

Studying Attack Patterns in Packet Captures

- Port scans — many connection attempts to different ports from the same source IP in a short time.
- SYN floods — huge numbers of SYN packets without completing the handshake (a DoS technique).
- Suspicious DNS requests — unusually long or random-looking domain names may indicate malware command-and-control traffic.

Example: If Wireshark shows one external IP sending hundreds of SYN packets to different ports on your server within seconds, that is a strong sign of a port scan — the reconnaissance phase of an attack.

Tcpdump

Tcpdump is the command-line equivalent of Wireshark, commonly used directly on Linux servers where a graphical interface isn't available. It captures packets and can save them to a file (readable later in Wireshark) or print a summary directly on screen.

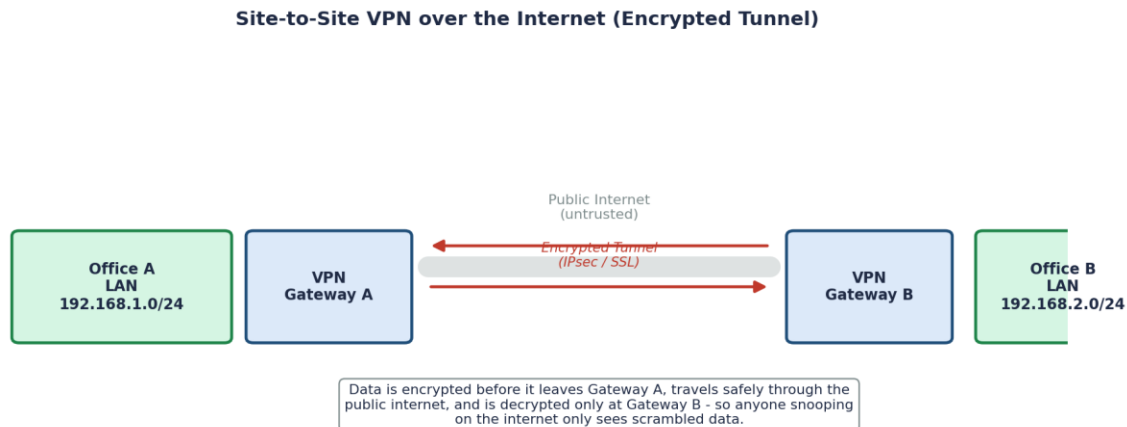
- Installation: usually available via the package manager (e.g., `apt install tcpdump`).
- Basic usage: `tcpdump -i eth0` captures live traffic on interface eth0.

IMPORTANT: Tcpdump and Wireshark use the SAME underlying capture format (pcap), so a file captured with tcpdump can be opened and analyzed visually later in Wireshark.

UNIT 4 — Virtual Private Network (VPN)

4.1 Introduction to VPN

A VPN (Virtual Private Network) creates a secure, encrypted 'tunnel' across an untrusted network (usually the public internet), so that data travelling through it stays private, just as if the two ends were connected by a private cable.



- Confidentiality — data is encrypted so eavesdroppers cannot read it.
- Integrity — data cannot be silently modified in transit without detection.
- Authentication — both ends verify each other's identity before the tunnel is set up.

VPN Functions

- Allows remote employees to securely access the company's internal network from home or while travelling.
- Connects two separate office branches together over the internet (site-to-site).
- Hides the user's real IP address and location (privacy use case).

- Bypasses geographic/network restrictions (though this can raise policy/legal questions depending on context).

VPN Protocols / Characteristics

Protocol	Key characteristic
PPTP	One of the oldest VPN protocols; fast but considered weak/insecure by modern standards.
L2TP	Often paired with IPsec (L2TP/IPsec) for encryption; more secure than plain PPTP.
SSTP	Uses SSL/TLS (like HTTPS) to tunnel traffic; works well through firewalls since it uses port 443.
IPsec	A whole suite of protocols for authenticating and encrypting IP packets; industry standard for site-to-site VPNs.
OpenVPN	Open-source, uses SSL/TLS, considered very secure and flexible; works on both Linux and Windows.

4.2 Types of VPN

Secure VPN

A Secure VPN uses strong cryptographic protocols (like IPsec or SSL/TLS) to guarantee confidentiality and integrity, regardless of how untrusted the underlying network is.

Trusted VPN

A Trusted VPN does NOT necessarily rely on encryption. Instead, it relies on a trusted service provider who guarantees that your traffic will travel over a specific, dedicated, private path/circuit that no one else can use — the trust comes from the provider's guarantee, not from cryptography.

IMPORTANT: Exam trap: A Trusted VPN can exist WITHOUT strong encryption, because security comes from a dedicated/guaranteed path, not from scrambling the data. A Secure VPN's protection comes specifically from encryption.

Hybrid VPN

A Hybrid VPN combines both approaches — it uses a trusted provider's dedicated path AND adds strong encryption on top, giving the benefits of both models.

4.3 IPsec — Internet Protocol Security

IPsec is a suite of protocols that authenticates and encrypts each IP packet in a data stream. It works at the Network Layer, which means it can protect ANY application running on top of it without each application needing its own security.

- AH (Authentication Header) — provides integrity and authentication, but NOT encryption/confidentiality.
- ESP (Encapsulating Security Payload) — provides encryption (confidentiality) as well as integrity/authentication.

Tunnel Mode vs Transport Mode

Mode	What gets encrypted	Typical use case
Tunnel Mode	The ENTIRE original IP packet (header + payload) is encrypted and wrapped inside a new IP packet.	Site-to-site VPN (gateway to gateway)
Transport Mode	Only the PAYLOAD (data) is encrypted; the original IP header stays visible.	End-to-end host-to-host communication

IPv6 VPN

As networks migrate to IPv6, VPN configurations must also support IPv6 addressing. IPsec itself was originally designed with IPv6 in mind, so it maps cleanly, but administrators must remember to configure VPN and firewall rules for IPv6 separately from IPv4 (similar to the ip6tables point in Unit 2).

Split Tunnel vs Full Tunnel VPN

Type	Behavior	Trade-off
Full Tunnel	ALL of the user's internet traffic is routed through the VPN.	Most secure, but slower and uses more corporate bandwidth.
Split Tunnel	Only traffic destined for the corporate network goes through the VPN; everything else (e.g., Netflix, general browsing) goes directly to the internet.	Faster and saves bandwidth, but less traffic is protected/monitored.

IMPORTANT: Remember: Full Tunnel = maximum security, more bandwidth used. Split Tunnel = better performance, smaller security footprint.

4.4 VPN Vulnerabilities, Attacks & Real Incidents

- Misconfigured VPNs — leaving default/weak settings can expose the entire internal network to attackers.
- Credential reuse attacks — attackers use stolen passwords (leaked from other breaches) to log into VPN portals, since many users reuse passwords.
- Outdated VPN software with unpatched vulnerabilities has been the entry point for several major ransomware attacks in real incidents.
- Weak/legacy protocols like plain PPTP can be broken with modern computing power.

Example: A well-known pattern in real incidents: attackers scan the internet for VPN gateways running old, unpatched firmware, exploit a known vulnerability to get initial access, and then move laterally into the internal network.

VPN Configuration Types Covered in Labs

- OpenVPN (Linux & Windows) — site-to-site connectivity.
- pfSense OS — installation and VPN configuration.

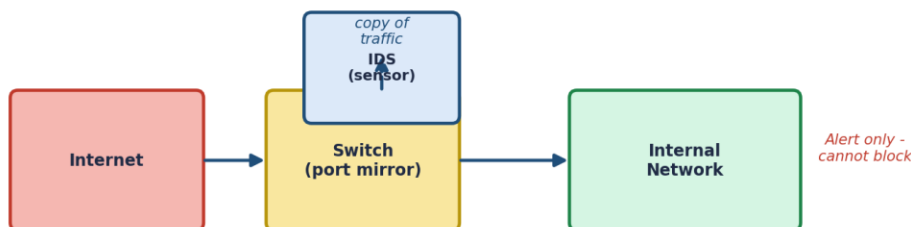
- UTM VPN Configuration — configuring VPN as part of a Unified Threat Management appliance.
- PPTP/SSTP VPN setup under Windows Server using RRAS (Routing and Remote Access Service).
- L2TP VPN configuration.

UNIT 5 — Intrusion Detection & Prevention Systems (IDS/IPS)

5.1 Introduction to IDS and IPS

IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) are security tools that monitor network or host activity looking for signs of an attack. A firewall decides who is ALLOWED in based on rules; an IDS/IPS looks at the traffic that IS allowed and checks whether it is behaving maliciously.

IDS - Intrusion DETECTION System (out-of-band / passive - a copy of traffic)



IPS - Intrusion PREVENTION System (inline / active - sits directly in traffic path)



Feature	IDS	IPS
Position	Out-of-band (works on a COPY of traffic)	Inline (sits directly in the traffic path)
Action	Detects and ALERTS only	Detects AND actively blocks/drops malicious traffic
Risk if it fails	Traffic keeps flowing (no protection lost)	Can accidentally block legitimate traffic (false positive) or cause a bottleneck

IMPORTANT: Simple memory trick: IDS = Detection = alarm bell (tells you). IPS = Prevention = a locked gate (stops the intruder itself).

Types of Attacks & Security Events

- Reconnaissance — attacker gathers information (port scanning, ping sweeps) before the real attack.
- Exploitation — attacker takes advantage of a vulnerability to gain access.
- Denial of Service (DoS/DDoS) — attacker overwhelms a system so legitimate users cannot use it.
- Malware-based attacks — viruses, worms, trojans, ransomware.
- A 'Security Event' is any observable occurrence in a system (e.g., a login attempt); it becomes an 'Incident' only when it actually violates security policy or causes harm.

Vulnerability, Design & Implementation Weaknesses

- Design flaws — the system was designed insecurely from the start (e.g., a protocol with no authentication).
- Implementation flaws — the design was fine, but the coding/configuration introduced a bug (e.g., a buffer overflow).

5.2 Attack Types, Intruder Types & IDS/IPS Categories

Traditional vs Distributed Attacks

- Traditional Attack — comes from a single source/attacker.
- Distributed Attack — comes from MANY sources at once (e.g., a botnet performing a DDoS attack), making it far harder to block by simply blacklisting one IP.

Intruder Types

- Masquerader — an outsider who pretends to be a legitimate authorized user (using stolen credentials).
- Misfeasor — a legitimate user who misuses their authorized access (insider abusing their own privileges).
- Clandestine User — someone (insider or outsider) who takes supervisory/admin control to hide their actions and evade being logged/audited.

Types of IDS (based on WHERE it monitors)

Type	Monitors	Example tool
NIDS (Network-based)	Traffic across a network segment	Snort, Suricata
HIDS (Host-based)	Activity/logs on one individual system	OSSEC

IPS Categories

- Network-based IPS (NIPS) — inline device protecting the whole network segment.
- Host-based IPS (HIPS) — software agent protecting an individual host.
- Wireless IPS (WIPS) — monitors wireless traffic/spectrum for rogue access points and wireless attacks.
- Network Behavior Analysis (NBA) — looks for unusual traffic FLOWS/volumes rather than exact signatures (good for detecting DDoS and worm spread).

Defense in Depth

Defense in depth means using MULTIPLE, LAYERED security controls so that if one layer fails, the next layer still protects the system — just like a castle has a moat, walls, AND guards, rather than relying on just one.

Example: Layers might include: perimeter firewall → DMZ → IDS/IPS → antivirus on each host → strong user authentication → data encryption → regular backups.

IDS and IPS Analysis Scheme / Detection Methodologies

Method	How it works	Strength / Weakness
Signature-based Detection	Matches traffic against a database of KNOWN attack patterns (like antivirus signatures).	Very accurate for known attacks, but CANNOT catch brand-new (zero-day) attacks.
Anomaly-based Detection	Learns a baseline of 'normal' behavior, then flags anything that deviates from it.	Can catch unknown/zero-day attacks, but has more false positives (may flag unusual-but-legitimate activity).

Stateful Protocol Analysis	Compares observed protocol behavior against known-good protocol standards (RFCs).	Good at spotting protocol misuse, but resource-intensive.
----------------------------	---	---

IMPORTANT: Signature-based = looks for what's KNOWN to be bad. Anomaly-based = looks for what's DIFFERENT from normal. Together they cover more ground than either alone.

Principles of IDS

- Should monitor continuously, in real time wherever possible.
- Should generate reliable alerts — minimizing both false positives (false alarms) and false negatives (missed attacks).
- Should be resistant to attackers trying to evade or disable it.
- Should log enough detail to support later investigation (forensics).

Threat Hunting Model

Threat hunting is a PROACTIVE process where security analysts actively search for hidden threats that automated tools (IDS/IPS/antivirus) may have missed, instead of only waiting for an alert to appear.

- Usually driven by a hypothesis (e.g., 'Could an attacker be using this specific technique in our network?').
- The MITRE ATT&CK Framework is commonly used as a reference library of real-world adversary tactics and techniques to guide threat hunting.

5.3 Symptoms of Attacks, Architecture & DoS/DDoS

Symptoms of Attacks

- Unusual spikes in network traffic or CPU/memory usage.
- Repeated failed login attempts.
- Unexpected new user accounts or privilege changes.
- Unusual outbound traffic to unknown external IPs (possible data exfiltration).

Tiered (Tired) Architecture

A tiered/multi-tier architecture separates a system into layers — commonly Presentation Tier (user interface), Application/Logic Tier (business logic), and Data Tier (database). This separation itself is a security control: even if an attacker compromises the presentation tier, they still must break through additional layers to reach the sensitive data tier.

Sensors — Network-based & Host-based

- Network-based sensors (e.g., Snort) are placed at strategic network points (like the DMZ boundary) to inspect traffic flows.
- Host-based sensors (e.g., OSSEC) are installed directly on individual servers/endpoints to watch local logs, file integrity, and processes.
- Agents — the actual software components running on sensors that collect data and forward it to a central manager.
- Functions of IDS Agents — capturing data, applying basic local detection rules, and forwarding alerts/events to the central IDS Manager.
- IDS Manager — the central console that aggregates alerts from all sensors/agents, correlates them, and presents them to the security team.

Denial of Service (DoS) & Distributed DoS (DDoS)

A DoS attack tries to make a system or service unavailable to its legitimate users — usually by overwhelming it with traffic or requests, or by exploiting a bug that crashes the service. A DDoS attack is the same goal, but launched from MANY distributed sources simultaneously (often a botnet of infected devices), making it much harder to block.

DoS & DDoS Mitigation

- Rate limiting — restricting the number of requests/connections allowed from a single source in a given time (can be done with iptables).
- Network layer mitigation — filtering malicious traffic at the ISP/network edge before it reaches your servers, using techniques like blackholing or scrubbing centers.
- Application layer mitigation — using a reverse proxy/WAF (Web Application Firewall) to filter malicious HTTP requests that a network firewall can't see.
- Cloud-based DDoS mitigation services can absorb massive volumetric attacks using huge distributed infrastructure that a single organization could never build alone.

Example: A rate-limiting iptables rule could allow only 20 new connections per minute from a single IP address to a web server, stopping a single-source flood while barely affecting normal users.

UNIT 6 — Log Analysis, SIEM & Monitoring Tools

6.1 Introduction to Log Analysis

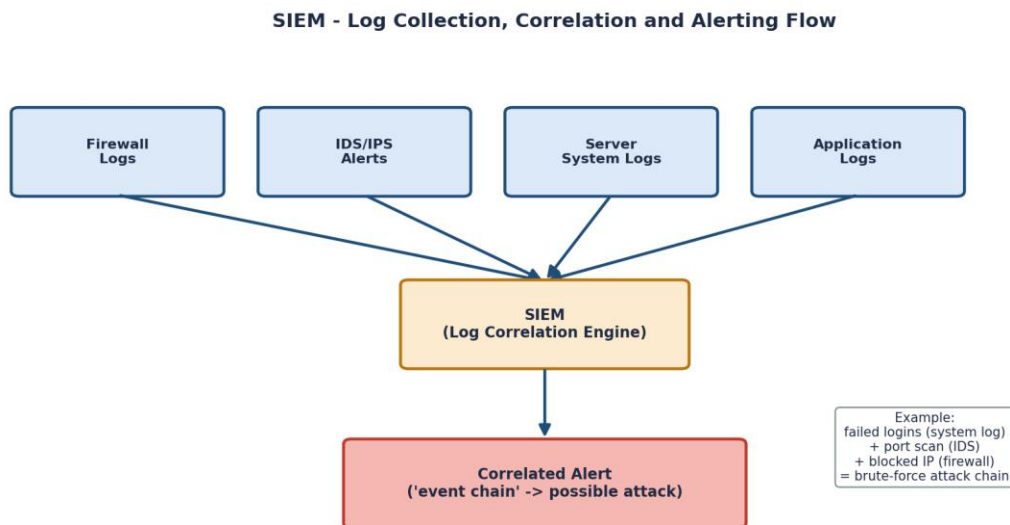
A Log is simply a recorded entry of an event that happened on a system — for example, a login attempt, a firewall block, or an application error. Logs are the 'diary' of everything happening across your infrastructure.

- Every device (firewall, server, router, application) generates its own separate logs.
- A Log Analyser is a tool that reads, filters, and makes sense of these logs so humans don't have to read raw text files line by line.

IMPORTANT: A single log by itself often looks harmless. The real value comes from CORRELATING logs from multiple sources together — this is exactly what a SIEM does.

Introduction to SIEM

SIEM stands for Security Information and Event Management. It is a centralized platform that collects logs from many different sources across the organization, correlates related events, and raises alerts when a pattern suggests an attack.



- SIEM Log Forwarding Configuration — each device/server must be configured to send (forward) its logs to the central SIEM server, usually using protocols like Syslog.
- SIEM Log Correlation and Event Triggering — the SIEM engine analyzes incoming logs together and triggers an alert only when a suspicious COMBINATION of events is seen, not just a single log line.

Example: A single failed login is normal. But the SIEM correlating '50 failed logins from one IP' + 'a port scan alert from the IDS' + 'a successful login right after' together builds a strong picture of a successful brute-force attack — something no single log source would reveal alone.

6.2 Snort — Signature-based NIDS/IPS

Snort is one of the most widely used open-source Network Intrusion Detection/Prevention Systems. It inspects network traffic in real time and compares it against a large set of written 'rules' (signatures).

Writing Basic Snort Rules

A Snort rule has two parts: the RULE HEADER (action, protocol, source/destination IP and port) and the RULE OPTIONS (in parentheses — alert message, content to match, rule ID).

- Example structure: alert icmp any any -> any any (msg:"ICMP Flood Detected"; sid:1000001;)
- Rules can be written to detect: Port scans, ICMP floods, and suspicious HTTP activity (like SQL injection attempts in a URL).

IMPORTANT: Snort rules always follow the same shape: ACTION PROTOCOL SOURCE_IP SOURCE_PORT -> DEST_IP DEST_PORT (OPTIONS). Learning this pattern lets you read almost any Snort rule.

Testing Snort (Windows & Linux) and IDS Architecture

- Snort can run on both Windows and Linux, though Linux is more common in production due to better performance and integration with Netfilter/iptables.
- IDS Architecture generally consists of: Sensors (collect traffic) → Analysis Engine (matches rules) → Manager/Console (displays alerts) → Database (stores events for later review).

Bypassing an IDS (Evasion Techniques)

Attackers sometimes try to sneak malicious traffic past an IDS without triggering its signatures. Common evasion techniques include:

- Fragmentation — splitting malicious payloads across many small packets so the full malicious pattern is never seen in one single packet.
- Encoding/Obfuscation — disguising attack strings (e.g., using different character encodings) so they don't match the exact signature text.
- Encryption — hiding the attack payload inside encrypted traffic (like HTTPS) that a basic IDS cannot inspect without decryption.
- Timing attacks — sending attack traffic very slowly over a long period to avoid triggering rate/threshold-based detection.

IMPORTANT: This is exactly why Defense in Depth matters — even if an attacker evades the IDS, other layers (like endpoint antivirus, strict firewall rules, or SIEM correlation) may still catch the activity.

Syslog Server & BASE

- Syslog is a standard protocol used by network devices/servers to send log messages to a central Syslog server for storage and analysis.
- BASE (Basic Analysis and Security Engine) is a web front-end used to browse, search, and analyze alerts generated by Snort, stored in a database.

6.3 Suricata & ELK Stack (Threat Hunting)

- Suricata is a modern, open-source IDS/IPS engine (like Snort) that also supports multi-threading and deeper protocol analysis, and can be configured with custom rules for intrusion prevention.

- The ELK Stack = Elasticsearch (stores/searches data) + Logstash (collects/processes logs) + Kibana (visual dashboards). Security teams use ELK to perform large-scale threat hunting by searching and visualizing huge volumes of logs quickly.

Example: A security analyst uses Kibana dashboards built on the ELK stack to visually spot a sudden spike in failed authentication attempts across hundreds of servers within seconds — something that would take hours to find by reading raw text logs.

6.4 Nagios — Infrastructure Monitoring

Nagios is a monitoring tool used to check the HEALTH and AVAILABILITY of hosts, services, and resources — not specifically an intrusion detection tool, but a critical part of the overall defense/monitoring picture, since it tells you when something is down or behaving abnormally (which could be caused by an attack, like a DoS).

- Nagios Sensor Configuration works on both Windows and Linux hosts.
- Can monitor RAM usage and Hard Disk usage, alerting when they cross a defined threshold.
- Can be integrated with Email services to automatically notify administrators the moment a problem is detected.

IMPORTANT: Remember the distinction: Snort/Suricata/OSSEC detect SECURITY threats (malicious activity). Nagios monitors OPERATIONAL HEALTH (is the server up, is RAM/disk okay). Both feed useful information into a SOC (Security Operations Center) and SIEM.

SOC (Security Operations Center) Workflows

A SOC is the team and facility responsible for continuously monitoring, detecting, analyzing, and responding to security incidents. A simplified SOC workflow follows this order:

1. Collect — logs, alerts, and sensor data flow in from firewalls, IDS/IPS, servers, and monitoring tools like Nagios.
2. Detect & Correlate — SIEM correlates events into meaningful alerts (as explained earlier).
3. Triage/Investigate — analysts review the alert to confirm if it's a real incident or a false positive.
4. Respond — contain the threat (e.g., block an IP with iptables, isolate a host), then recover and document lessons learned.

FINAL RECAP — Key Concepts at a Glance

Use this page as a last-minute revision sheet the night before an exam.

Core Ideas

IMPORTANT: Vulnerability (weakness) -> Threat (danger) -> Risk (chance of loss) -> Countermeasure (the fix). This chain is the foundation of the entire subject.

IMPORTANT: Firewall decides WHO gets in. IDS/IPS checks WHETHER allowed traffic is behaving maliciously. They work TOGETHER, not as substitutes for each other.

IMPORTANT: IDS = Detect only (passive, out-of-band). IPS = Detect + Block (active, inline).

IMPORTANT: Signature-based detection = matches KNOWN attacks. Anomaly-based detection = flags anything DIFFERENT from normal. Use both together for best coverage.

IMPORTANT: iptables chains: INPUT (traffic to this box), OUTPUT (traffic from this box), FORWARD (traffic passing through this box as a router).

IMPORTANT: VPN Tunnel mode encrypts the WHOLE packet (site-to-site). Transport mode encrypts only the PAYLOAD (host-to-host).

IMPORTANT: Full Tunnel VPN = everything protected, slower. Split Tunnel VPN = only company traffic protected, faster.

IMPORTANT: Defense in Depth = many layers of security, so no single failure exposes the whole system - Firewall + DMZ + IDS/IPS + Antivirus + Encryption + Backups.

IMPORTANT: SIEM's power comes from CORRELATING logs from multiple sources (firewall + IDS + system logs) - a single log rarely tells the full story.

Quick Formula to Remember

$\text{Risk} = \text{Likelihood of a Threat} \times \text{Impact if it happens}$. Reduce Risk by reducing Vulnerability (patching) OR reducing Exposure (DMZ, firewall) OR adding Countermeasures (IDS/IPS, VPN, monitoring).

QUIZ — 40 Multiple Choice Questions (NDC Full Syllabus)

Instructions: This quiz covers the whole syllabus — Information Security basics, Firewalls, iptables, Wireshark, VPN, and IDS/IPS/SIEM. Some questions are easy (direct recall) and some are tricky (require understanding, not just memorizing). Attempt all 40 before checking the Answer Key & Explanations section at the end of this document. *(Read It)*

Q1. What does the CIA triad stand for in information security? *[Easy]*

- A) Confidentiality, Integrity, Availability
- B) Central Intelligence Agency
- C) Control, Inspection, Audit
- D) Confidentiality, Inspection, Access

Q2. A weakness in a system that can be exploited is called a: *[Easy]*

- A) Threat
- B) Risk
- C) Vulnerability
- D) Countermeasure

Q3. Risk is best defined as: *[Tricky]*

- A) Any weakness in software
- B) The entity that exploits a weakness
- C) The likelihood and impact of a threat exploiting a vulnerability
- D) A firewall rule

Q4. OWASP Top 10 primarily lists: *[Easy]*

- A) Top 10 web application security risks
- B) Top 10 antivirus tools
- C) Top 10 firewalls
- D) Top 10 programming languages

Q5. The NIST Cybersecurity Framework's core functions include Identify, Protect, Detect, Respond and: *[Easy]*

- A) Encrypt
- B) Recover
- C) Report
- D) Escalate

Q6. A DMZ (De-Militarized Zone) is used to: *[Easy]*

- A) Store backup data
- B) Host public-facing servers separated from the internal trusted network
- C) Encrypt VPN traffic
- D) Block all incoming traffic

Q7. Which firewall implementation uses two firewalls with a DMZ between them? *[Easy]*

- A) Screened subnet (dual/two-firewall) architecture
- B) Single packet filter only
- C) Proxy chaining
- D) VPN tunneling

Q8. A firewall that tracks the state of active connections (like a TCP handshake) is called: *[Tricky]*

- A) Packet filtering firewall
- B) Stateful inspection firewall
- C) Circuit-level gateway only
- D) Static firewall

Q9. iptables is a firewall utility native to which operating system? *[Easy]*

- A) Windows
- B) Linux
- C) macOS
- D) Android

Q10. In iptables, which built-in chain handles packets destined for the local system itself? *[Tricky]*

- A) FORWARD
- B) OUTPUT
- C) INPUT
- D) PREROUTING

Q11. In iptables, the FORWARD chain is used for packets that: *[Easy]*

- A) Originate from the local machine
- B) Are destined to the local machine
- C) Pass through the machine acting as a router
- D) Are dropped automatically

Q12. Which iptables target immediately discards a packet without informing the sender? *[Tricky]*

- A) REJECT
- B) ACCEPT
- C) DROP
- D) LOG

Q13. A Next-Generation Firewall (NGFW) adds which capability beyond a traditional firewall? *[Easy]*

- A) Only IP blocking
- B) Application-awareness and deep packet inspection
- C) Only port blocking
- D) Only logging

Q14. Compared to stateless firewalls, stateful firewalls: *[Tricky]*

- A) Are always slower and less secure
- B) Remember the context of a connection, offering better security
- C) Cannot filter based on IP address
- D) Do not support TCP/IP

Q15. A reverse proxy (like Nginx/Squid) is typically placed: *[Easy]*

- A) On the client's device only
- B) In front of backend servers to handle client requests on their behalf
- C) Inside a VPN tunnel only
- D) Only in wireless networks

Q16. UTM stands for: *[Easy]*

- A) Unified Threat Management
- B) Universal Transport Model
- C) User Traffic Monitor
- D) Unified Tunnel Mode

Q17. Server load balancing primarily helps to: *[Tricky]*

- A) Encrypt all traffic
- B) Distribute incoming requests across multiple servers to improve performance and availability
- C) Detect malware signatures
- D) Replace the need for firewalls

Q18. Wireshark is mainly used to: *[Easy]*

- A) Configure firewalls
- B) Capture and analyze network packets
- C) Send emails securely
- D) Create VPN tunnels

Q19. In Wireshark, a 'display filter' is used to: *[Tricky]*

- A) Decide which packets are captured at the NIC
- B) Show/hide already-captured packets in the view
- C) Encrypt captured packets
- D) Block malicious IPs

Q20. QoS (Quality of Service) parameters commonly include: *[Easy]*

- A) Latency, Jitter, Packet loss
- B) Threat, Risk, Vulnerability
- C) Encryption, Hashing, Signing
- D) DMZ, NAT, Proxy

Q21. VPN stands for: *[Easy]*

- A) Virtual Private Network
- B) Verified Public Node
- C) Virtual Protected Node
- D) Virtual Public Network

Q22. The main purpose of a VPN is to: *[Tricky]*

- A) Speed up the internet connection always
- B) Create a secure, encrypted tunnel over an untrusted network
- C) Replace antivirus software
- D) Act as a firewall only

Q23. IPsec operating in Tunnel mode encrypts: *[Easy]*

- A) Only the payload
- B) The entire original IP packet (header + payload)
- C) Nothing, it only authenticates
- D) Only the TCP port number

Q24. IPsec Transport mode is typically used for: *[Tricky]*

- A) Site-to-site VPN between two networks

- B) End-to-end communication between two hosts, encrypting only the payload
- C) Wireless-only communication
- D) DNS resolution

Q25. A 'Split Tunnel' VPN configuration means: *[Easy]*

- A) All traffic goes through the VPN
- B) Only traffic destined for the corporate network goes through the VPN; other traffic goes directly to the internet
- C) The VPN tunnel is physically split into two cables
- D) Two VPN gateways are always used for one connection

Q26. A 'Trusted VPN' (as opposed to a Secure VPN) primarily relies on: *[Tricky]*

- A) Strong encryption algorithms only
- B) A trusted service provider guaranteeing a dedicated path/circuit, sometimes without strong encryption
- C) No provider trust at all
- D) Public Wi-Fi hotspots

Q27. PPTP and SSTP are examples of: *[Easy]*

- A) Firewall types
- B) VPN protocols
- C) IDS types
- D) Log formats

Q28. IDS stands for: *[Easy]*

- A) Intrusion Detection System
- B) Internet Defense Server
- C) Internal Data Security
- D) Integrated Detection Software

Q29. The key functional difference between IDS and IPS is: *[Tricky]*

- A) IDS can block traffic, IPS cannot
- B) IDS only detects/alerts (passive), IPS can detect and actively block (inline)
- C) They are the same thing
- D) IDS works only on Windows

Q30. A Network-based IDS (NIDS) like Snort monitors: *[Easy]*

- A) Traffic across the network segment
- B) Only a single host's file system
- C) Only email servers
- D) Only DNS queries

Q31. A Host-based IDS (HIDS) like OSSEC monitors: *[Easy]*

- A) Network traffic across all subnets
- B) Activity/logs on an individual host system
- C) Only wireless traffic
- D) Only the firewall

Q32. Signature-based detection identifies attacks by: *[Tricky]*

- A) Learning normal baseline behavior and flagging deviations

- B) Matching traffic patterns against known attack signatures
- C) Randomly sampling packets
- D) Encrypting traffic

Q33. Anomaly-based detection identifies attacks by: *[Tricky]*

- A) Matching against a database of known attack patterns only
- B) Flagging behavior that deviates from an established normal baseline
- C) Blocking all UDP traffic
- D) Using only IP address blacklists

Q34. 'Defense in depth' refers to: *[Easy]*

- A) Relying on a single strong firewall
- B) Using multiple layered security controls so that if one fails, others still protect the system
- C) Using only antivirus software
- D) Disabling all network monitoring

Q35. Which of these is an example of a Denial of Service objective? *[Tricky]*

- A) Stealing confidential data quietly
- B) Making a service or resource unavailable to legitimate users
- C) Encrypting files for ransom only
- D) Elevating user privileges

Q36. The MITRE ATT&CK framework is mainly used to: *[Easy]*

- A) Encrypt VPN traffic
- B) Catalog and describe real-world adversary tactics and techniques
- C) Configure iptables rules
- D) Manage DNS records

Q37. SIEM primarily helps organizations by: *[Easy]*

- A) Replacing the need for firewalls
- B) Collecting and correlating logs from multiple sources to detect attack patterns
- C) Only backing up data
- D) Only managing VPN certificates

Q38. In a SIEM, 'log correlation' means: *[Tricky]*

- A) Storing logs without any analysis
- B) Linking related events from different sources (e.g., firewall + IDS + system logs) to identify a bigger attack pattern
- C) Deleting old logs automatically
- D) Encrypting logs only

Q39. Nagios is primarily used for: *[Easy]*

- A) Intrusion prevention only
- B) Monitoring the health/status of hosts, services, and resources (e.g., RAM, disk)
- C) VPN tunneling
- D) Firewall rule writing

Q40. 'Bypassing an IDS' (evasion) most commonly involves: *[Tricky]*

- A) Turning off the internet

- B) Techniques like fragmentation, encoding, or encryption to hide malicious traffic from signature matching
- C) Buying a new IDS license
- D) Only using HTTPS for legitimate browsing

ANSWER KEY — Detailed Explanations

Below is the correct answer for every question, along with a short explanation of the underlying concept. Use this section to revise the reasoning, not just memorize the letter.

Q1. What does the CIA triad stand for in information security?

Correct Answer: A) Confidentiality, Integrity, Availability

Explanation: The CIA triad is the core model of information security: Confidentiality (only authorized people see data), Integrity (data isn't altered), Availability (data/service is accessible when needed).

Q2. A weakness in a system that can be exploited is called a:

Correct Answer: C) Vulnerability

Explanation: A Vulnerability is the flaw/weakness itself (e.g., unpatched software). A Threat is what could exploit it; Risk is the resulting likelihood/impact; a Countermeasure is the fix.

Q3. Risk is best defined as:

Correct Answer: C) The likelihood and impact of a threat exploiting a vulnerability

Explanation: Risk = Likelihood × Impact. It is not the weakness itself (that's vulnerability) nor the attacker (that's threat) — it is the calculated exposure to loss.

Q4. OWASP Top 10 primarily lists:

Correct Answer: A) Top 10 web application security risks

Explanation: OWASP (Open Web Application Security Project) publishes the Top 10 most critical web application security risks, updated periodically.

Q5. The NIST Cybersecurity Framework's core functions include Identify, Protect, Detect, Respond and:

Correct Answer: B) Recover

Explanation: The five core functions of the NIST Cybersecurity Framework are Identify, Protect, Detect, Respond, and Recover.

Q6. A DMZ (De-Militarized Zone) is used to:

Correct Answer: B) Host public-facing servers separated from the internal trusted network

Explanation: A DMZ holds public-facing servers (web, mail, DNS) in a semi-trusted zone so that even if they are compromised, the internal LAN stays protected behind another firewall.

Q7. Which firewall implementation uses two firewalls with a DMZ between them?

Correct Answer: A) Screened subnet (dual/two-firewall) architecture

Explanation: The screened-subnet (dual-firewall) architecture places the DMZ between two separate firewalls — one facing the internet, one facing the internal LAN — for stronger security.

Q8. A firewall that tracks the state of active connections (like a TCP handshake) is called:

Correct Answer: B) Stateful inspection firewall

Explanation: A Stateful Inspection Firewall keeps a state table of active connections and only allows traffic matching a legitimate, already-established connection — unlike simple packet filters which check each packet in isolation.

Q9. iptables is a firewall utility native to which operating system?

Correct Answer: B) Linux

Explanation: iptables is the standard command-line firewall utility built into the Linux kernel's Netfilter framework.

Q10. In iptables, which built-in chain handles packets destined for the local system itself?

Correct Answer: C) INPUT

Explanation: The INPUT chain governs packets whose final destination is the local machine. OUTPUT is for packets originating locally, and FORWARD is for packets merely passing through (routed).

Q11. In iptables, the FORWARD chain is used for packets that:

Correct Answer: C) Pass through the machine acting as a router

Explanation: FORWARD applies to traffic that is neither generated by nor destined for the local machine — it is simply being routed/forwarded through it to another network.

Q12. Which iptables target immediately discards a packet without informing the sender?

Correct Answer: C) DROP

Explanation: DROP silently discards a packet — the sender gets no response at all. REJECT also discards it but sends back an error message (like ICMP unreachable), which reveals the firewall's presence.

Q13. A Next-Generation Firewall (NGFW) adds which capability beyond a traditional firewall?

Correct Answer: B) Application-awareness and deep packet inspection

Explanation: NGFWs inspect traffic at the application layer (Deep Packet Inspection), understand which application generated the traffic, and often include built-in intrusion prevention and identity-based rules.

Q14. Compared to stateless firewalls, stateful firewalls:

Correct Answer: B) Remember the context of a connection, offering better security

Explanation: Stateful firewalls track ongoing connections (state), allowing them to distinguish legitimate response traffic from unsolicited/spoofed traffic — giving stronger security than stateless packet filtering.

Q15. A reverse proxy (like Nginx/Squid) is typically placed:

Correct Answer: B) In front of backend servers to handle client requests on their behalf

Explanation: A reverse proxy sits in front of one or more backend servers, forwarding client requests to them and returning responses — hiding the backend servers' real identity/IP.

Q16. UTM stands for:

Correct Answer: A) Unified Threat Management

Explanation: UTM (Unified Threat Management) bundles multiple security functions — firewall, antivirus, IDS/IPS, VPN, content filtering — into a single appliance.

Q17. Server load balancing primarily helps to:

Correct Answer: B) Distribute incoming requests across multiple servers to improve performance and availability

Explanation: Load balancing spreads client requests across many servers, preventing any single server from being overwhelmed, improving both response times and fault tolerance.

Q18. Wireshark is mainly used to:

Correct Answer: B) Capture and analyze network packets

Explanation: Wireshark is a packet analyzer (packet sniffer) — it captures live network traffic and lets you inspect every packet's contents in detail.

Q19. In Wireshark, a 'display filter' is used to:

Correct Answer: B) Show/hide already-captured packets in the view

Explanation: Display filters only affect what is SHOWN on-screen from packets already captured. Capture filters (a different syntax) decide what gets captured in the first place.

Q20. QoS (Quality of Service) parameters commonly include:

Correct Answer: A) Latency, Jitter, Packet loss

Explanation: Latency (delay), Jitter (variation in delay), and Packet loss are the classic QoS metrics used to measure real-world network performance experienced by users.

Q21. VPN stands for:

Correct Answer: A) Virtual Private Network

Explanation: VPN = Virtual Private Network, a technology that creates a secure, private tunnel over a public/untrusted network.

Q22. The main purpose of a VPN is to:

Correct Answer: B) Create a secure, encrypted tunnel over an untrusted network

Explanation: A VPN's core purpose is confidentiality and integrity of data in transit — achieved by tunneling and typically encrypting traffic over an otherwise untrusted network like the internet.

Q23. IPsec operating in Tunnel mode encrypts:

Correct Answer: B) The entire original IP packet (header + payload)

Explanation: In Tunnel mode, the ENTIRE original IP packet (both header and payload) is encrypted and encapsulated inside a new IP packet — commonly used for site-to-site (gateway-to-gateway) VPNs.

Q24. IPsec Transport mode is typically used for:

Correct Answer: B) End-to-end communication between two hosts, encrypting only the payload

Explanation: Transport mode encrypts only the payload (data), leaving the original IP header visible — suited for direct host-to-host communication rather than gateway-to-gateway tunneling.

Q25. A 'Split Tunnel' VPN configuration means:

Correct Answer: B) Only traffic destined for the corporate network goes through the VPN; other traffic goes directly to the internet

Explanation: Split tunneling routes only corporate-bound traffic through the VPN, while general internet traffic (e.g., streaming, browsing) goes directly out — improving performance but reducing the scope of protection/monitoring.

Q26. A 'Trusted VPN' (as opposed to a Secure VPN) primarily relies on:

Correct Answer: B) A trusted service provider guaranteeing a dedicated path/circuit, sometimes without strong encryption

Explanation: A Trusted VPN's security comes from the provider's guarantee of a dedicated, private path — not necessarily from cryptography, unlike a Secure VPN which relies specifically on encryption.

Q27. PPTP and SSTP are examples of:

Correct Answer: B) VPN protocols

Explanation: PPTP and SSTP are both VPN tunneling protocols, alongside others like L2TP, IPsec, and OpenVPN.

Q28. IDS stands for:

Correct Answer: A) Intrusion Detection System

Explanation: IDS = Intrusion Detection System — it monitors traffic/hosts and raises alerts on suspicious activity, but does not block traffic itself.

Q29. The key functional difference between IDS and IPS is:

Correct Answer: B) IDS only detects/alerts (passive), IPS can detect and actively block (inline)

Explanation: IDS works passively (out-of-band, on a copy of traffic) and only alerts. IPS sits inline in the traffic path and can actively drop/block malicious traffic in real time.

Q30. A Network-based IDS (NIDS) like Snort monitors:

Correct Answer: A) Traffic across the network segment

Explanation: NIDS tools like Snort and Suricata monitor traffic flowing across a network segment, inspecting packets against rules/signatures.

Q31. A Host-based IDS (HIDS) like OSSEC monitors:

Correct Answer: B) Activity/logs on an individual host system

Explanation: HIDS tools like OSSEC run directly on an individual host, watching local logs, file integrity, and system activity rather than network-wide traffic.

Q32. Signature-based detection identifies attacks by:

Correct Answer: B) Matching traffic patterns against known attack signatures

Explanation: Signature-based detection compares traffic against a database of KNOWN attack patterns — very accurate for known threats but blind to brand-new (zero-day) attacks.

Q33. Anomaly-based detection identifies attacks by:

Correct Answer: B) Flagging behavior that deviates from an established normal baseline

Explanation: Anomaly-based detection builds a baseline of normal behavior and flags deviations — this can catch unknown/zero-day attacks but tends to generate more false positives than signature-based detection.

Q34. 'Defense in depth' refers to:

Correct Answer: B) Using multiple layered security controls so that if one fails, others still protect the system

Explanation: Defense in depth uses several layered controls (firewall, DMZ, IDS/IPS, antivirus, authentication, encryption) so that no single point of failure compromises the whole system.

Q35. Which of these is an example of a Denial of Service objective?

Correct Answer: B) Making a service or resource unavailable to legitimate users

Explanation: The defining goal of a DoS/DDoS attack is to make a target service/resource UNAVAILABLE to its legitimate users, typically by overwhelming it with traffic or requests.

Q36. The MITRE ATT&CK framework is mainly used to:

Correct Answer: B) Catalog and describe real-world adversary tactics and techniques

Explanation: MITRE ATT&CK is a widely-used knowledge base cataloguing real-world attacker tactics and techniques, commonly used to guide threat hunting and detection engineering.

Q37. SIEM primarily helps organizations by:

Correct Answer: B) Collecting and correlating logs from multiple sources to detect attack patterns

Explanation: SIEM (Security Information and Event Management) centralizes logs from many sources (firewall, IDS, servers) and correlates them to spot attack patterns that no single log source would reveal alone.

Q38. In a SIEM, 'log correlation' means:

Correct Answer: B) Linking related events from different sources (e.g., firewall + IDS + system logs) to identify a bigger attack pattern

Explanation: Log correlation connects related events across different log sources — for example, combining a firewall block, an IDS port-scan alert, and repeated failed logins into a single recognizable attack chain.

Q39. Nagios is primarily used for:

Correct Answer: B) Monitoring the health/status of hosts, services, and resources (e.g., RAM, disk)

Explanation: Nagios is an infrastructure monitoring tool that checks the health/availability of hosts and services (like RAM and hard disk usage), alerting administrators when thresholds are crossed.

Q40. 'Bypassing an IDS' (evasion) most commonly involves:

Correct Answer: B) Techniques like fragmentation, encoding, or encryption to hide malicious traffic from signature matching

Explanation: IDS evasion techniques (fragmentation, encoding/obfuscation, encryption, slow/timing-based attacks) aim to disguise malicious traffic so it doesn't match known signatures or thresholds.